common attacks, but you can still shoot yourself in the foot. Make sure it's not your app making headlines for being breached!

Summary

- XSS attacks involve malicious users injecting content into your app, typically to run malicious JavaScript when users browse your app. You can prevent XSS injection attacks by always encoding unsafe input before writing it to a page. Razor Pages do this automatically unless you use the `@Html.Raw()` method, so use it sparingly and carefully.
- CSRF attacks are a problem for apps that use cookie-based authentication, such as ASP.NET Core Identity. These attacks rely on the fact that browsers automatically send cookies to a website. A malicious website could create a form that `POST`s to your site, and the browser will send the authentication cookie with the request. This allows malicious websites to send requests as though they're the logged-in user.
- You can mitigate CSRF attacks using antiforgery tokens, which involve writing a hidden field in every form that contains a random string based on the current user. A similar token is stored in a cookie. A legitimate request will have both parts, but a forged request from a malicious website will have only the cookie half; it cannot re-create the hidden field in the form. By validating these tokens, your API can reject forged requests.